GUIDE TECHNIQUE ET FONCTIONNEL

Comment fonctionne Sentinel PME ?

Flux de données, architecture, scoring, alertes SOC, intégration SIEM et parcours utilisateur - explication fondée sur l'implémentation réelle du projet.

PLATEFORME	VERSION DOCUMENT	DATE
Sentinel PME	1.0	10 octobre 2026

PFA - Plateforme web de Threat Intelligence et d'alerte précoce pour les petites et moyennes entreprises.

Sommaire

Le document suit le trajet d'une donnée depuis sa source jusqu'à la décision de l'analyste.

Sommaire 2

01 Rôle et positionnement de la plateforme 4

Utilisateurs et droits . . . 4

02 Architecture générale 5

Démarrage de l'application . . . 5

03 Collecte des sources de Threat Intelligence 6

Planification et lancement manuel . . . 6

Réponse attendue d'un lancement manuel . . . 6

04 Pipeline de traitement d'une menace 7

05 Scoring explicable de 0 à 100 8

Niveaux de risque . . . 8

Exemple calculé . . . 8

06 Modèle de données et persistance 9

Règles de persistance . . . 9

07 Alertes et workflow SOC 10

Déduplication des alertes . . . 10

Export SIEM et webhook . . . 10

08 Fiches réflexes opérationnelles 11

Relation avec les menaces . . . 11

09 API REST : endpoints principaux 12

10 Fonctionnement du frontend 13

Gestion des erreurs . . . 13

11 Authentification, sécurité et traçabilité 14

Journal d'audit . . . 14

Point d'attention production . . . 14

12 Scénario complet de bout en bout **15**

13 Exploitation locale et diagnostic **16**

Commandes de lancement sous Windows PowerShell . . . 16

Contrôles rapides . . . 16

Tests de validation . . . 16

14 Limites actuelles et évolutions possibles **17**

Limites connues . . . 17

Évolutions prioritaires . . . 17

15 Glossaire et références **18**

Références du projet . . . 18

Références méthodologiques . . . 18

Conclusion . . . 18

01 Rôle et positionnement de la plateforme

Sentinel PME centralise des renseignements cyber publics, les transforme en indicateurs homogènes, calcule une priorité compréhensible et aide une PME à traiter les alertes importantes.

Positionnement exact. Le projet est un système d'alerte précoce avec des fonctions « SIEM-light ». Il ne collecte pas massivement les journaux internes d'un parc informatique et ne remplace ni un antivirus/EDR, ni un pare-feu, ni un SIEM complet comme Wazuh, Elastic Security ou Splunk.

La valeur apportée se situe à trois niveaux :

1. **Veille**
   Rassembler des CVE, URL malveillantes, adresses IP suspectes et indicateurs de compromission provenant de plusieurs services.
2. **Priorisation**
   Attribuer un score de risque de 0 à 100 et expliquer chaque facteur qui participe au calcul.
3. **Réponse**
   Créer les alertes importantes, organiser leur traitement et proposer une fiche réflexe adaptée au type de menace.

Utilisateurs et droits

Rôle	Consultation	Actions autorisées
Administrateur	Toutes les vues	Créer des utilisateurs, lancer les collecteurs, analyser des menaces, gérer les alertes, consulter l'audit.
Analyste	Dashboard, menaces, alertes, sources, fiches	Lancer les collecteurs, créer/analyser une menace, assigner et résoudre une alerte.
Responsable PME / viewer	Dashboard et données de veille	Lecture seule des menaces, alertes, explications et fiches réflexes.

02 Architecture générale

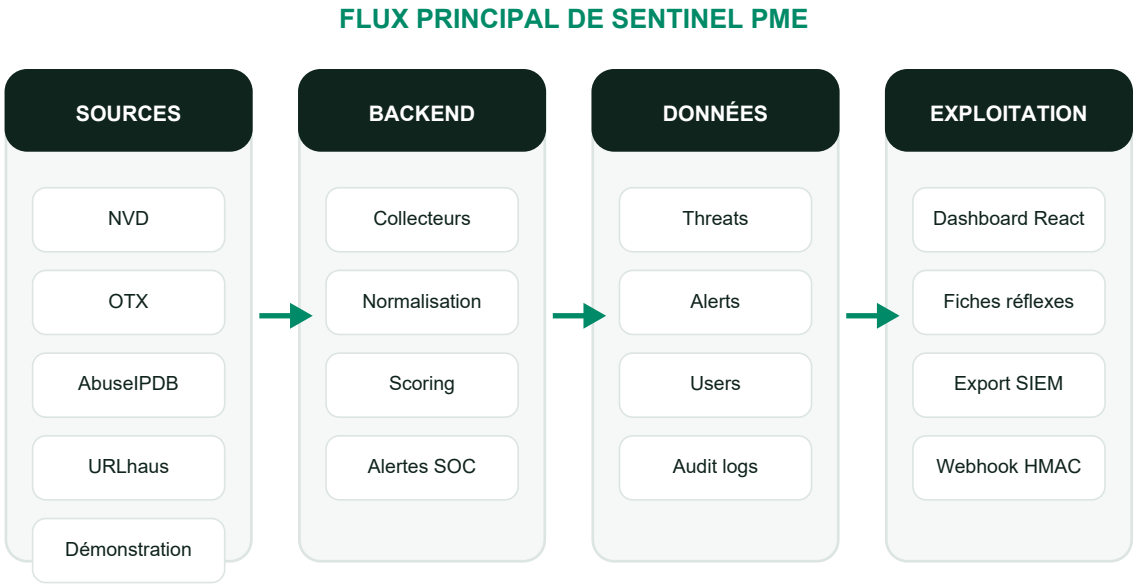


Figure 1 - Les quatre blocs principaux et le sens du flux de données.

L'application est organisée en deux projets :

- **Backend FastAPI :** expose l'API REST, authentifie les utilisateurs, exécute les collecteurs, calcule les scores, persiste les données et produit les alertes.
- **Frontend React :** appelle l'API avec Axios et présente les informations sous forme de dashboard, listes, détails et formulaires SOC.
- **SQLAlchemy + SQLite :** stocke les menaces, alertes, utilisateurs et journaux d'audit. Alembic gère les évolutions de schéma.
- **APScheduler :** déclenche la collecte automatiquement tant que le backend est en fonctionnement.

Démarrage de l'application

1. **Initialisation**
   FastAPI appelle init_db(), crée les tables manquantes et ouvre la base configurée par DATABASE_URL.
2. **Données initiales**
   Si aucune menace n'existe, le collecteur sample insère les données de démonstration. Si aucun utilisateur n'existe, le compte administrateur initial est créé.
3. **Planification**
   Le planificateur démarre les tâches de collecte et programme une première exécution environ 30 secondes après le lancement.
4. **Service web**
   L'API écoute sur le port 8000 ; le frontend Vite écoute normalement sur le port 5173 et communique avec l'API via CORS.

03 Collecte des sources de Threat Intelligence

Chaque collecteur transforme la réponse distante en objets **ThreatInput** compatibles avec le reste de la plateforme.

Source	Données récupérées	Configuration	Comportement réel
NVD	CVE publiées durant les 30 derniers jours	NVD_API_KEY facultative mais recommandée	Récupère jusqu'à 20 entrées récentes ; transforme le score CVSS en sévérité medium/high/critical.
AlienVault OTX	IOC des pulses suivies : IP, domaines, URL, hashes, CVE	OTX_API_KEY obligatoire	Interroge les pulses abonnés et classe les IOC en malware ou vulnerability.
AbuseIPDB	Adresses IP fortement signalées	ABUSEIPDB_API_KEY obligatoire	Demande la blacklist avec un niveau de confiance minimum de 90 %.
URLhaus	URL malveillantes récentes	URLHAUS_AUTH_KEY obligatoire	Marque une URL online comme high, sinon medium.
Sample	Jeu local de démonstration	Aucune clé	Garantit qu'une installation neuve contient des menaces et des alertes démontrables.

Planification et lancement manuel

- Sample, URLhaus, NVD et OTX suivent **COLLECTOR_INTERVAL_MINUTES**, 60 minutes par défaut.
- AbuseIPDB suit un intervalle séparé, **ABUSEIPDB_INTERVAL_MINUTES**, 360 minutes par défaut, afin de respecter plus facilement les quotas.
- Un administrateur ou analyste peut lancer une source depuis la page Sources. L'endpoint est limité à 6 appels par minute.
- Une panne d'une source planifiée est journalisée et n'empêche pas les autres collecteurs de fonctionner.

Réponse attendue d'un lancement manuel

```
POST /api/collectors/nvd/run
{ "source": "nvd", "threats_processed": 20 }
```

04 Pipeline de traitement d'une menace

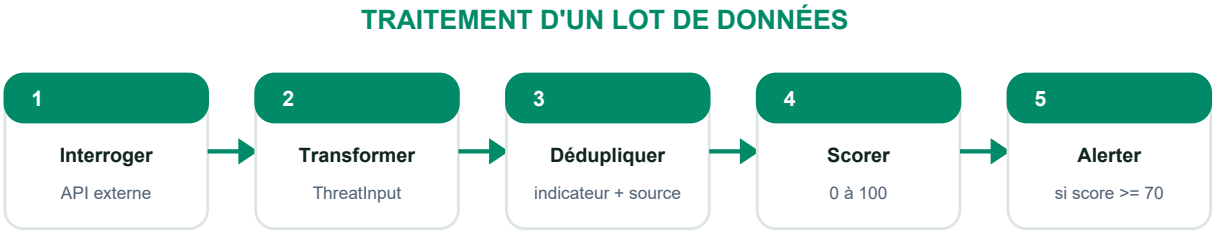


Figure 2 - Le même pipeline est utilisé pour une collecte automatique, manuelle ou une saisie via l'API.

1. **Validation**
   Pydantic vérifie l'indicateur, son type, le type de menace, la source, la sévérité et les dates.
2. **Recherche de corroboration**
   La base compte les autres sources ayant déjà rapporté exactement le même indicateur.
3. **Scoring**
   Le moteur additionne les points des facteurs puis limite le résultat à 100.
4. **Fiche réflexe**
   Le type de menace sélectionne une action recommandée et une procédure opérationnelle.
5. **Déduplication**
   La contrainte unique (indicator, source) évite de dupliquer un signal lors de la collecte suivante. L'enregistrement existant est mis à jour.
6. **Alerte**
   Après sauvegarde, le service crée une alerte unique si le score est supérieur ou égal à 70.

Important : la corrélation multi-sources n'agrège pas les lignes en une seule menace. Chaque source conserve sa ligne pour la traçabilité, mais le score gagne un bonus lorsque le même indicateur est confirmé ailleurs.

05 Scoring explicable de 0 à 100

Le score n'est pas produit par une intelligence artificielle opaque. Il repose sur des règles déterministes, auditées dans **risk_scoring.py**.

Facteur	Barème exact	Interprétation
Sévérité	low 5 ; medium 20 ; high 35 ; critical 50	Poids principal communiqué par la source.
Type d'indicateur	IP 5 ; domaine 7 ; URL 8 ; CVE 12 ; hash 6	Capacité de l'indicateur à guider une action.
Type de menace	phishing 10 ; malware 12 ; ransomware 18 ; brute force 8 ; vulnerability 12 ; suspicious IP 7	Impact probable du scénario.
Fiabilité de source	NVD 12 ; URLhaus 11 ; AbuseIPDB 9 ; OTX 9 ; manual/sample 4	Confiance accordée à l'origine.
Bonus CVE	+5	Ajouté quand indicator_type = cve.
Exploitation connue	+15	Ajouté lorsque known_exploited = true.
Ciblage PME	+10	Ajouté lorsque targets_smes = true.
Récence	0 à 7 j : 8 ; 8 à 30 j : 5 ; 31 à 90 j : 2 ; sinon 0	Favorise les signaux récents.
Corroboration	+6 par autre source, maximum +12	Augmente la confiance sans saturer indéfiniment le score.

Niveaux de risque

Score	Niveau	Conséquence dans Sentinel PME
0-39	Low	Surveillance ; aucune alerte automatique.
40-69	Medium	Visible et filtrable ; aucune alerte automatique.
70-89	High	Création d'une alerte high.
90-100	Critical	Création d'une alerte critical.

Exemple calculé

Une CVE **high** issue de la **NVD**, publiée depuis moins de 7 jours, sans exploitation connue ni ciblage PME : 35 (sévérité) + 12 (CVE) + 12 (vulnérabilité) + 12 (NVD) + 5 (bonus CVE) + 8 (récence) = **84/100**. Elle génère donc une alerte high.

06 Modèle de données et persistance

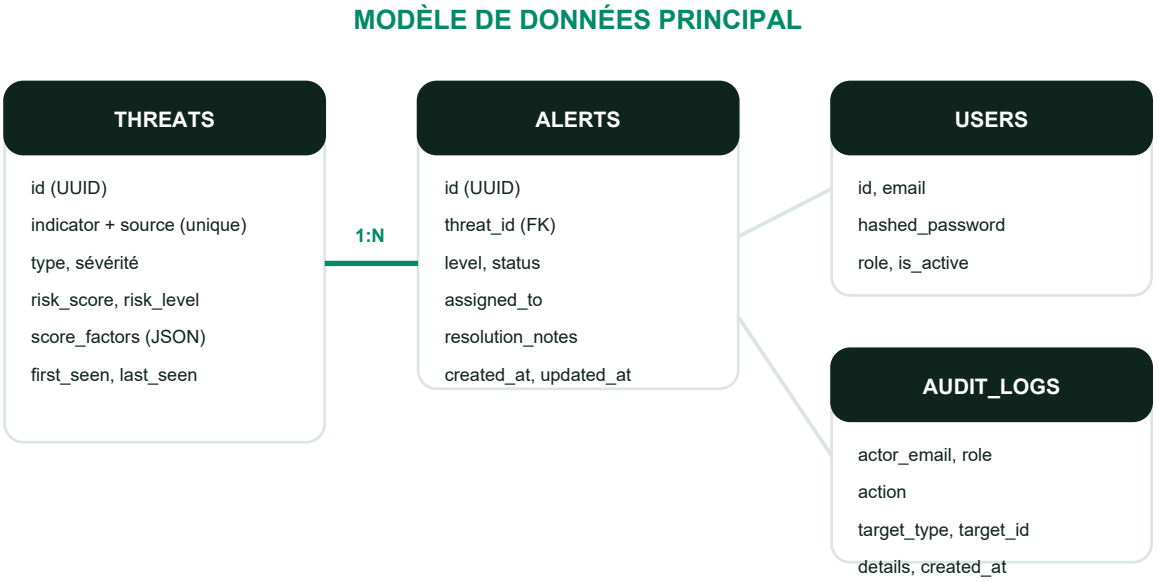
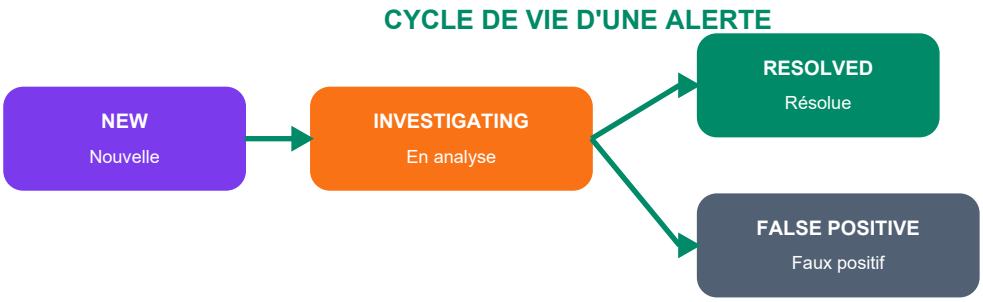


Figure 3 - Entités essentielles du schéma SQLAlchemy.

Règles de persistance

- Les identifiants sont des UUID stockés sous forme de chaînes.
- Une menace possède zéro ou plusieurs alertes ; une alerte automatique est reliée à une menace par threat_id.
- La suppression d'une menace entraîne la suppression de ses alertes associées par cascade.
- score_factors est une colonne JSON qui conserve l'explication au moment du calcul.
- updated_at d'une alerte change quand le workflow SOC est modifié.
- En développement, SQLite est utilisée. DATABASE_URL permet de pointer vers une autre base compatible SQLAlchemy ; Alembic reste le mécanisme de migration recommandé.

07 Alertes et workflow SOC



L'acquittement historique place directement l'alerte dans l'état RESOLVED.

Figure 4 - États autorisés du mini-workflow SOC.

Une alerte automatique contient le niveau, un titre, un message, le canal dashboard et la menace associée. L'analyste peut ensuite :

- passer le statut de **new** à **investigating** ;
- renseigner **assigned_to** avec l'email ou l'identifiant de la personne responsable ;
- ajouter des **resolution_notes** décrivant l'analyse et les actions effectuées ;
- terminer avec **resolved** ou **false_positive**. Ces deux statuts mettent également acknowledged à true.

Déduplication des alertes

Une seule alerte est créée par menace. Une collecte répétée met à jour la menace mais ne produit pas une nouvelle alerte identique.

Export SIEM et webhook

Mécanisme	Déclenchement	Contenu et usage
Export SIEM	GET /api/alerts/{id}/siem-event	JSON stable schema_version 1.0 : alerte, menace, score et action recommandée. Peut être relayé vers Wazuh, Elastic ou Splunk.
Webhook SOC	À la création d'une nouvelle alerte	POST vers WEBHOOK_URL. Si WEBHOOK_SECRET existe, le corps est signé en HMAC-SHA256 dans X-Sentinel-Signature.

La panne du webhook ne bloque jamais l'enregistrement de l'alerte : l'erreur réseau est journalisée et le flux applicatif continue.

08 Fiches réflexes opérationnelles

Le backend fournit neuf procédures détaillées : phishing, malware, ransomware, force brute, vulnérabilité, IP suspecte, compte compromis, fuite de données et menace non classifiée.

Bloc d'une fiche	Utilité pendant l'incident
Priorité et pilote	Indique l'urgence et la fonction qui doit coordonner les actions.
Phases chronologiques	Découpe les gestes entre actions immédiates, qualification/confinement et restauration/surveillance.
Preuves à préserver	Évite de perdre les emails originaux, logs, IOC, empreintes et heures utiles à l'analyse.
Critères d'escalade	Indique quand contacter un prestataire spécialisé, maCERT, la direction ou les autorités compétentes.
À ne pas faire	Réduit les actions irréversibles : effacer trop tôt, payer dans la précipitation, éteindre un poste sans raison, etc.
Références officielles	Relie les consignes à NIST, DGSSI, CISA, CNIL et Cybermalveillance.gouv.fr.

Relation avec les menaces

Lors de l'analyse d'un ThreatInput, son threat_type permet de sélectionner la première action de la fiche correspondante. Cette action est copiée dans recommended_action afin de rester visible dans la menace, l'alerte, l'export SIEM et le webhook.

09 API REST : endpoints principaux

Méthode	Endpoint	Accès	Fonction
POST	/api/auth/login	Public	Authentification OAuth2 form et émission du JWT.
GET	/api/auth/me	Authentifié	Retourne l'utilisateur courant.
POST/GET	/api/auth/users	Admin	Créer ou lister les comptes.
GET	/api/stats	Authentifié	Compteurs du dashboard.
GET	/api/threats	Authentifié	Liste paginée et filtrable ; total dans X-Total-Count.
GET	/api/threats/{id}	Authentifié	Détail d'une menace.
GET	/api/threats/{id}/explain	Authentifié	Score, niveau et facteurs persistés.
POST	/api/threats/analyze	Admin/Analyste	Valide, score et sauvegarde un ThreatInput.
POST	/api/threats/manual	Admin/Analyste	Crée une menace avec source=manual.
GET/PATCH	/api/alerts ; /api/alerts/{id}	Selon action	Lister et mettre à jour le workflow SOC.
GET	/api/alerts/{id}/siem-event	Authentifié	Exporter l'événement SIEM JSON.
GET/POST	/api/collectors ; /api/collectors/{name}/run	Selon action	État et lancement d'un collecteur.
GET	/api/reflex-sheets	Authentifié	Retourne les procédures de réponse.
GET	/api/audit-logs	Admin	Consulte les 1 à 500 dernières traces.
GET	/health	Public	État du backend et environnement.

Les endpoints d'écriture importants appliquent une limitation de débit : 30/minute pour la création/analyse de menaces, 10/minute pour les alertes de test et 6/minute pour l'exécution manuelle d'un collecteur.

10 Fonctionnement du frontend

Le frontend est une application React monopage. Les routes métier sont protégées : sans jeton valide, ProtectedRoute renvoie l'utilisateur vers /login.

Page	Appels API	Ce que l'utilisateur peut faire
Connexion	POST /api/auth/login	S'authentifier ; le JWT, le rôle et l'email alimentent le contexte d'authentification.
Vue d'ensemble	GET /api/stats, /api/threats, /api/alerts	Voir les compteurs, les cinq derniers indicateurs et les trois alertes récentes.
Menaces	GET /api/threats	Rechercher et filtrer par risque, type ou source ; ouvrir une menace.
Détail menace	GET /api/threats/{id} et /explain	Lire l'indicateur, l'action recommandée et chaque facteur du score.
Alertes	GET/PATCH /api/alerts	Assigner, passer en investigation, documenter, résoudre et télécharger l'événement SIEM.
Sources	GET/POST /api/collectors	Vérifier les clés configurées, le volume et la dernière collecte ; lancer une source.
Fiches réflexes	GET /api/reflex-sheets	Choisir un incident et suivre une procédure chronologique.

Gestion des erreurs

- Axios ajoute automatiquement le Bearer token à chaque requête.
- Une réponse 401 déclenche la suppression de la session locale et le retour vers /login.
- Les pages possèdent des états de chargement, d'erreur et de liste vide.
- Les boutons d'écriture ne sont affichés qu'aux rôles admin et analyst.

11 Authentification, sécurité et traçabilité

Contrôle	Implémentation
Mot de passe	Stockage sous forme de hash ; aucun mot de passe en clair dans la base.
Session	JWT signé avec JWT_SECRET_KEY, algorithme configurable (HS256 par défaut), durée 480 minutes par défaut.
Autorisation	Dépendances FastAPI par rôle : admin, analyst, viewer.
CORS	Origines explicitement autorisées ; méthodes GET, POST, PATCH et OPTIONS.
En-têtes HTTP	nosniff, DENY pour les frames, Referrer-Policy, CSP restrictive ; HSTS en production.
Protection contre l'abus	SlowAPI limite les endpoints d'écriture.
Secrets	Variables d'environnement ; le secret JWT par défaut est refusé en production.
Audit	auth.login, auth.create_user, collector.run, alert.update et alert.acknowledge sont enregistrés.

Journal d'audit

Chaque trace conserve l'acteur, son rôle, l'action, le type et l'identifiant de la cible, des détails textuels et la date. Seul l'administrateur peut lire l'endpoint /api/audit-logs.

Point d'attention production

Changer obligatoirement le mot de passe administrateur initial et JWT_SECRET_KEY, utiliser HTTPS, restreindre CORS, protéger les sauvegardes de base et envisager PostgreSQL pour une exploitation multi-utilisateur durable.

12 Scénario complet de bout en bout

Exemple : une nouvelle CVE importante est publiée et collectée depuis la NVD.

1. **Connexion**
   L'administrateur s'authentifie. Une entrée auth.login est écrite dans audit_logs.
2. **Collecte**
   Le planificateur ou l'utilisateur appelle le collecteur NVD. L'API récupère les CVE des 30 derniers jours.
3. **Normalisation**
   La CVE devient un ThreatInput : indicator=CVE-..., type=cve, threat_type=vulnerability, source=nvd.
4. **Scoring**
   Le moteur additionne sévérité, type, source, bonus CVE, récence et éventuels bonus contextuels.
5. **Sauvegarde**
   La paire (CVE, nvd) est insérée ou mise à jour. Les facteurs sont enregistrés dans score_factors.
6. **Alerte**
   Si le score atteint 70, une alerte high ou critical est créée une seule fois. Le webhook est tenté s'il est configuré.
7. **Investigation**
   L'analyste assigne l'alerte, passe son statut à investigating et ouvre l'explication du score.
8. **Réponse**
   Il consulte la fiche « vulnérabilité » : identifier les actifs exposés, appliquer le correctif et rechercher une exploitation.
9. **Intégration**
   Il télécharge l'événement SIEM schema 1.0 pour l'envoyer à Wazuh, Elastic ou Splunk.
10. **Clôture**
    Il ajoute ses notes, passe l'alerte à resolved et laisse une trace alert.update dans le journal d'audit.

13 Exploitation locale et diagnostic

Commandes de lancement sous Windows PowerShell

```
# Terminal 1 - Backend
cd backend
.\.venv\Scripts\Activate.ps1
alembic upgrade head
uvicorn app.main:app --reload --port 8000

# Terminal 2 - Frontend
cd frontend
npm install
npm run dev -- --port 5173
```

Contrôles rapides

Contrôle	Résultat attendu
http://localhost:8000/health	HTTP 200 avec status=ok.
http://localhost:8000/docs	Documentation Swagger interactive.
http://localhost:5173	Page de connexion puis dashboard après authentification.
Page Sources	Chaque clé absente est marquée « À configurer » ; une source prête affiche son volume et sa dernière collecte.
Collecte en échec	Vérifier la clé, le quota, la connexion réseau et les logs Uvicorn. Le frontend affiche un message d'échec.
Données anciennes	Lancer manuellement les collecteurs puis vérifier last_collected_at. Les données sample restent volontairement démonstratives.

Tests de validation

Backend : **pytest -q**. Frontend : **npm run test -- --run**, puis **npm run build** et **npm run lint**.

14 Limites actuelles et évolutions possibles

Limites connues

- Aucun agent n'est installé sur les postes de la PME ; la plateforme ne voit donc pas directement les processus, fichiers ou connexions internes.
- Le contexte métier reste limité tant qu'un inventaire d'actifs, de domaines et de logiciels n'est pas intégré.
- Le scoring est fondé sur des règles. Il est explicable et stable, mais ne remplace pas l'analyse humaine.
- SQLite convient au développement et à la démonstration ; une exploitation plus importante doit privilégier PostgreSQL, des sauvegardes et une supervision dédiée.
- Le webhook est générique ; les connecteurs Wazuh/Elastic/Splunk dédiés restent à développer.

Évolutions prioritaires

- Ajouter un inventaire d'actifs pour augmenter le score lorsqu'une CVE touche réellement un logiciel utilisé par la PME.
- Créer des règles de corrélation temporelle entre plusieurs indicateurs et événements.
- Ajouter des notifications email/Teams/Slack avec reprise en cas d'échec.
- Mettre en place PostgreSQL, Redis et une file de tâches pour séparer les collectes longues de l'API web.
- Ajouter une interface d'administration des comptes et une politique de rotation des secrets.

15 Glossaire et références

Terme	Définition
Threat Intelligence	Collecte et analyse d'informations permettant de comprendre les menaces cyber.
IOC	Indicator of Compromise : IP, domaine, URL, hash ou autre trace associée à une activité malveillante.
CVE	Identifiant public d'une vulnérabilité logicielle.
SOC	Security Operations Center : équipe ou fonction chargée de surveiller et traiter les alertes.
SIEM	Plateforme centralisant des journaux et événements de sécurité pour leur détection et leur investigation.
HMAC	Code d'authentification fondé sur un secret partagé ; utilisé ici pour signer le webhook.
JWT	Jeton signé portant l'identité et le rôle de l'utilisateur.

Références du projet

- README.md - objectifs, installation, fonctionnalités et endpoints.
- docs/08-integration-soc-siem.md - workflow SOC, export SIEM, webhook et audit.
- backend/app/services - scoring, collecte, alertes, notifications et fiches réflexes.
- frontend/src - parcours utilisateur, appels API et composants d'interface.

Références méthodologiques

- NIST SP 800-61 Rev. 3 - Incident Response Recommendations and Considerations for Cybersecurity Risk Management.
- DGSSI - Référentiel de gestion des incidents de cybersécurité.
- CISA - StopRansomware Guide et Known Exploited Vulnerabilities Catalog.
- Cybermalveillance.gouv.fr - fiches réflexes phishing, malware, ransomware et compromission de compte.
- CNIL - notification d'une violation de données personnelles.

Conclusion

Sentinel PME transforme des flux de veille hétérogènes en décisions simples : collecter, normaliser, scorer, alerter, expliquer et guider la réponse. Son architecture reste volontairement lisible pour un projet de niveau junior, tout en intégrant des pratiques concrètes de sécurité, de traçabilité et d'interopérabilité.